DNV·GL

WHITEPAPER

PROBABILITY AND UNCERTAINTY

Some things are more uncertain than others



SAFER, SMARTER, GREENER

Reference to part of this report which may lead to misinterpretation is not permissible.

No.	Date	Reason for Issue	Prepared by	Verified by	Approved by
0	2018-06	First issue			

Date: June / 2018

Prepared by DNV GL – Digital Solutions

© DNV GL AS. All rights reserved

This publication or parts thereof may not be reproduced or transmitted in any form or by any means, including copying or recording, without the prior written consent of DNV GL AS

Table of contents

1 ABSTRACT 1

2 INTRODUCTION 2

3 DIFFERENT WAYS OF VIEWING RISKS 3

4 DIFFERENT WAYS OF PRESENTING RISKS 10

5 CONCLUSION 13

6 REFERENCES 14

7 APPENDIX – FROM CERTAINTY TO TOTAL IGNORANCE 15

1 ABSTRACT

In this whitepaper, I discuss the fact that some things are more uncertain than others, which also applies for risk. Some people think there is a major difference between risk and uncertainty, but uncertainty is an integral part of risk.

Some think that for deliberate human actions within cyber security one should not try to estimate probability or likelihood of something happening. Yes, this is difficult, but one should not abandon the concept of likelihood, just because it is difficult. Within the domain of IT risk, deliberate human actions are only a subset of what could happen, and it is beneficial to treat the whole risk picture the same way, no matter what is causing the risk. Readers will also see various ways and examples of how to present the risk picture in terms of risk matrices and heat maps.

Some examples of fallacies when trying to estimate likelihood are discussed. These illustrate that the difficulty in estimating likelihood is not reserved for deliberate human actions only.

The appendix has examples grouped in various categories that range from what is 100% certain to things that are increasingly uncertain.

Rolf Lervik

2 INTRODUCTION

According to some authors, there is a large difference between risk and uncertainty. In economic theory, Maynard Keynes[1] and Frank Knight in 1921 made the following distinction:

"In case of risk all possible future events or consequences of an action or decision are known. However, the events that will actually materialise are unknown beforehand. In case of risk the probability calculus is applicable and provides a sound basis for risk management, cost/benefit analysis, budget planning, etc.

Both Keynes and Knight argued that often in human decisions not all possible outcomes of an action or decision can be known. These are cases of (fundamental) uncertainty. There are things people simply do not know in advance. In situations of uncertainty the probability calculus has no sound foundation. There is no objective basis for risk management, cost/benefit analysis and other control techniques."
(University of Groningen, Decision Making in a Complex and Uncertain World. Free online course.)

The message from the above is also reflected in the following comparison of risk and uncertainty.

BASIS FOR COMPARISON	RISK	UNCERTAINTY
Meaning	The probability of winning or losing something worthy is known as risk.	Uncertainty implies a situation where the future events are not known.
Ascertainment	It can be measured	It cannot be measured.
Outcome	Chances of outcomes are known.	The outcome is unknown.
Control	Controllable	Uncontrollable
Minimization	Yes	No
Probabilities	Assigned	Not assigned

Figure 1 - Comparison of risk and uncertainty (Surbhi, 2016)

In my experience, when performing IT risk analysis, the risks identified belong to a continuum between risk on the one hand, and uncertainty on the other. Risks are not always controllable, cannot always be measured, etc. In fact, I think the definitions above of risk versus uncertainty are too categorical and misleading. It may also be that these authors only think of risk in terms of quantitative risk. In risk, there is always some uncertainty involved. In many cases, chances of outcomes are not known, and probability (or likelihood) can only be qualitatively assessed or guessed. So how do we go about performing risk assessments, especially in the domain of IT risk and cyber security?

[1] Fact: Maynard Keynes, one of the most influential economists in the twentieth century, did not have any exams in economy (he followed one course some months without taking the final exam). He was a mathematician (Davidsen 2018).

3 DIFFERENT WAYS OF VIEWING RISKS

Probability is a number between 0 and 1; that is certain. This is a basic assumption, an axiom of probability theory. If p is the probability of the occurrence of an event, $1 - p$ is the probability of the non-occurrence of the event. The risk level is a function of probability and consequence, often calculated as *Probability* x *Consequence*. Sometimes it is possible to know probability very well, but other times it is very uncertain. In qualitative risk analysis, the concept of likelihood is often used[2].

The risks may be plotted in a risk matrix, showing likelihood and consequence, where the colours indicate which risks that can be accepted or not.



Figure 2 – Example of a 5x5 risk matrix

Another way to analyse risk is to combine threat, vulnerability and asset value to find the magnitude of the risk (NSM, 2016). In the figure below, the area of the triangle to the left indicates the risk. The risk can be reduced by tweaking one of the corners, in this case, reducing the vulnerability, as seen in the triangle to the right.

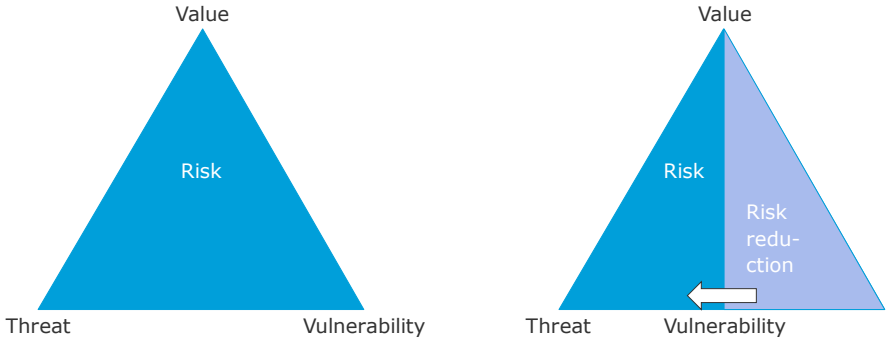


Figure 3 – Risk triangle. The area of the triangle indicates the risk level. An action to reduce vulnerability will reduce the area of the triangle. The figure is adapted from Botnan (2014)

In cyber security and security in general, the last approach is recommended by many. The doctrine is that they don't like to operate with probability, as this cannot be determined for deliberate actions. However, as I see it, these two approaches, risk matrix and risk triangle, are a matter of inclination or taste, and can be reconciled.

2 In English, there is a distinction between "probability" given by a numeric value and "likelihood" which is qualitatively assessed as e.g. low, medium or high. In Norwegian, there is no such distinction. We use "sannsynlighet" for both.

First, let us look at a risk analysis concerning availability of a service where we use the risk matrix approach. For instance, there are two fibre cables terminated in the system we are investigating.



Figure 4 – Illustration of example 1

1. In the first example we know that the fibres go in two different routes, so it is very unlikely that both will fail simultaneously. In this case, we can set Probability = Very Low. The consequence is a function of how important the service is and how long the outage lasts[3]. Let us say this is a very important service, and we assume it will be down for a considerable time, hence we set consequence = Very High.

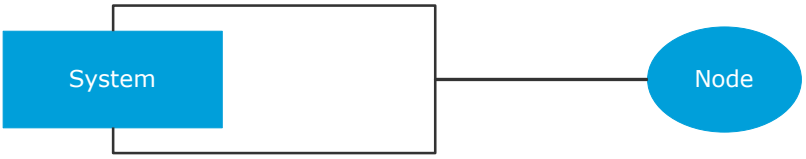


Figure 5 – Illustration of example 2

2. If we haven't inspected or there are some things we don't know, the fibre cables may go in the same duct for some distance so that both could be damaged simultaneously, representing a single-point-of-failure. Or the two fibres could have been rented from two telecom operators – but the two telecom operators rent fibre capacity from each other or from a third operator, so the two fibres could in fact be in the same cable. In worst case, it could even be the same fibre!

In this case, due to our ignorance, it is wise to set Probability = Medium. The consequence is still very high. The two versions of the risk could be shown in a risk matrix like this.

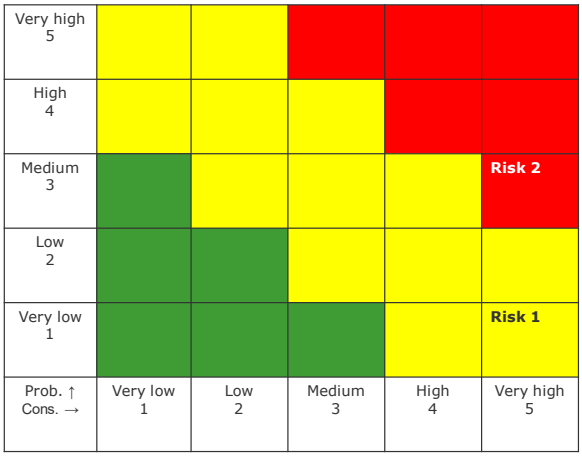


Figure 6 – Risk 1 and Risk 2 depicted in a risk matrix

Risk 2 is in the red area, indicating that something should be done with the risk; first more investigations, and later, depending on the outcome, actions to remove any single-point-of-failure.

[3] In telecom, it is customary to calculate the consequence of unavailability in customer minutes, i.e. how many customers are affected for how long.

Second, let us look at the task of performing a risk analysis concerning cyber security. We consider risks related to deliberate harmful acts by human threat agents. The challenge with these types of risk is that it is very difficult to assess the likelihood that someone will attempt and succeed in performing the harmful act.

Threat agents may be grouped according to the following generic types

- Thieves/criminals – someone who wants to steal something for gain
- Spies – someone who wants to get hold of secret information
- Saboteurs – someone who wants to deliberately disturb or manipulate the operation
- Terrorists – someone who wants to spread fear and get attention for their "cause"

These can be further divided into more specific types like "hackers/crackers", activists, unfaithful servants, etc., and even down to specific groups or organisations.

It may be difficult to distinguish between the generic threat types, since the act of spying is also a kind of theft, and may also be done as preparation for sabotage or terrorism, not only for industrial/governmental espionage. The difference between sabotage and terrorism may be in the eyes of the beholder.

In addition, for threat agents, there are skills, motives, opportunities and capabilities to be considered. Making malware for an advanced persistence threat (APT) could require a large software team with know-how, time and funding. A sophisticated APT can probably only be financed by a large organisation such as a nation-state. Stuxnet is an example of an APT. On the other hand, to launch a distributed denial of service (DDoS) attack, may be ordered on the internet by anyone (Malware as a Service). There is a large market for cybercrime (Ablon, Libicki and Golay, 2014).

Some threats could potentially affect anybody connected to the internet, while others are deliberately directed at special targets, if they are connected or not. Stuxnet was distributed on memory sticks. Thus, we can divide the threat agents into:

1. Those who want to attack "anybody"
2. Those who want to attack selected targets

Concerning the first group, one can assume with certainty that someone will try. If they succeed depends on the vulnerability and vigilance of those who are being attacked.

Organisations or individuals vary in how attractive a target they represent. Typically, critical infrastructure such as finance, telecom, energy, waterworks, etc. are attractive targets for spying and potential sabotage. Finance is also attractive for theft. Hence, for these branches and organisations it is sensible to assume that someone from the second group is motivated for attack. One can also assume that these threat agents are more advanced and have more resources than the average "hacker". They may also use social engineering to threat, bribe or fool insiders to co-operate.

Federal Emergency Management Agency (FEMA) in the United States uses the following formula to calculate risk of terrorist attack against high occupancy buildings[4]

Risk = Asset value x Threat rating x Vulnerability rating,

where all three risk factors have a value from 1 to 10. Below is an example of four different risk scenarios affecting various functions in a building.

Table 1-19: Total Risk Color Code

	Low Risk	Medium Risk	High Risk
Risk Factors Total	1-60	61-175	≥ 176

Table 1-20: Site Functional Pre-Assessment Screening Matrix*

Function	Cyber Attack	Armed Attack (single gunman)	Vehicle Bomb	CBR Attack
Administration	280	140	135	90
Asset Value	5	5	5	5
Threat Rating	8	4	3	2
Vulnerability Rating	7	7	9	9
Engineering	128	128	192	144
Asset Value	8	8	8	8
Threat Rating	8	4	3	2
Vulnerability Rating	2	4	8	9
Warehousing	96	36	81	54
Asset Value	3	3	3	3
Threat Rating	8	4	3	2
Vulnerability Rating	4	3	9	9
Data Center	360	128	216	144
Asset Value	8	8	8	8
Threat Rating	9	4	3	2
Vulnerability Rating	5	4	9	9

Figure 7- Example risk assessment of four different scenarios (from FEMA)

Is it possible to reconcile this approach with the risk matrix approach using likelihood and consequence? We may try the following formula for probability or likelihood for risk:

Probability = *P*(Threat) x *P*(Vulnerability),

and the risk level is given by[5]

Risk = Probability x Consequence = *P*(Threat) x *P*(Vulnerability) x Consequence.

This is indicated in the figure below.

[4] By multiplying the three values, the risk is no longer the area of the risk triangle, but rather the volume of a rectangular prism with sides: value, threat and vulnerability.

[5] We write multiplication sign in the formulas, but this should not be taken too literally. More generally, we can say that risk is a function of probability and consequence. It depends on the scales being used.

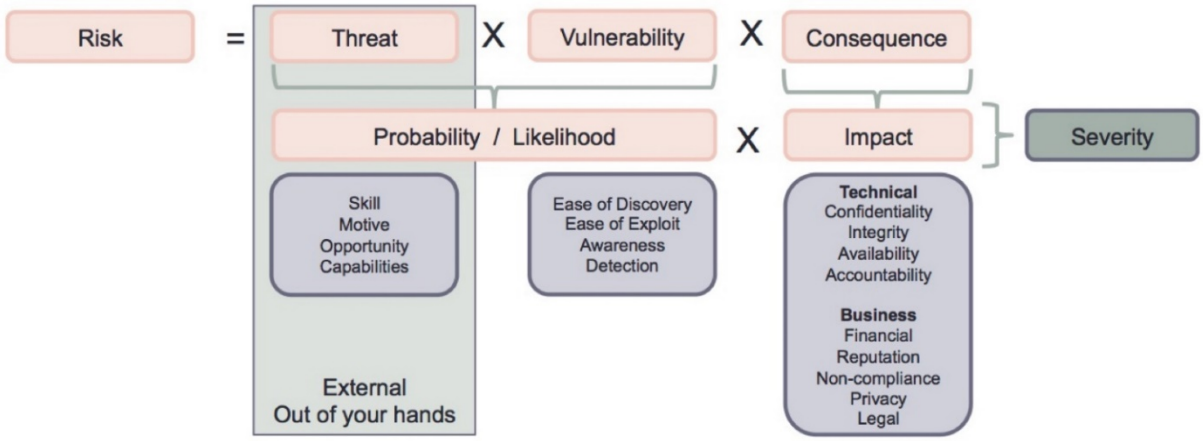


Figure 8 – The combination of threat[6], vulnerability and consequence (van Impe, 2017)

For deliberate human actions the likelihood is mostly given by the vulnerability and the motivation. The more vulnerable, the higher the likelihood[7]. The more existing controls and countermeasures, the less vulnerability and less likelihood. Consider the difference between an open door, a locked door, a door with two locks, surveillance and alarm system, etc. It should also be noted that the asset value influences the motivation of threat actors, and the asset value is also what is at stake for the business, i.e. the consequence or impact of a security breach or incident.

Suppose we have the risk for a laptop being stolen and it contains confidential information. If the hard drive is not encrypted, the perpetrator can extract the information in clear text and make use of it. If the hard drive is encrypted, it will be difficult or impossible for the thief to retrieve any useful information. In one view, we can say that the vulnerability has been reduced. On the other hand, it can be argued that the value for the thief has been reduced (ref. the risk triangle in Figure 3). Operating with likelihood and consequence, we could say that the consequence for a confidentiality breach has been greatly reduced. This is somewhat analogous to the case where someone tries to rob an ATM by brute force. In this case, there is a mechanism causing the bank notes to be dyed, so everybody can see that they have been stolen, making the money worthless for the robbers. When it is known that PCs have encryption and that ATMs have this mechanism for colouring the bank notes, this will again reduce the likelihood of theft.

Some people argue that for security risks caused by deliberate human action one should not use likelihood or probability at all. The Norwegian National Security Authority (NSM) only refers to threat, vulnerability and value (see for instance Botnan, 2014 and NSM, 2016). However, even if a threat is imminent, the likelihood derived from the vulnerability can still be used: After all, a computer system that can only be accessed by a few trusted employees that must have physical access to the computer room is much less likely to be attacked than a system connected to the internet. Of course, the likelihood that there is an unfaithful servant is not zero, and human errors can be made.

Also, it is beneficial to have security risks caused by deliberate human actions in the same risk matrix as other types of IT risks, for presentation and risk mitigation prioritisation. After all, risks due to deliberate human action is just a subset of all risks that could affect availability, integrity and confidentiality. See also Busmundrud, Maal, Hagness Kiran and Endregard (2015).

6 A comment on the figure. It should be noted that "Opportunity" in the Threat-box is not "External. Out of your hands". If a door is left open, that is an opportunity for someone to enter and steal. "Opportunity makes the thief."

7 "Vulnerability" could also be translated as "Ease of exploitation".

When performing a qualitative risk assessment using risk matrices, the absolute value of the probability as a number between 0 and 1 is not as important as the relative likelihood of the various risks. In many cases, we do not have any statistics on frequencies of various risks. The probability is our subjective judgement of the likelihood of an unwanted event. Some risks may also have a range of various outcomes concerning the consequences. A system may be unavailable for 10 minutes or 10 hours. Secret information may be disclosed, but who gets hold of it, and who will make use of that secret information? A good piece of advice is first to evaluate the consequence and afterwards the likelihood of that consequence. T. Aven (2010) defines risk as a "two-dimensional combination of

i. Events *A* and the consequences of those events *C*, and
ii. the associated uncertainties *U* (whether *A* will occur and what value *C* will take)"

There is uncertainty concerning whether the event will occur and what consequence it will have if it occurs.

Maybe the largest uncertainty in risk analysis, no matter how it is done, is a risk that is not identified, a risk that nobody has imagined. This has nothing to do with how the risk is analysed. It is not a risk with probability zero; the risk is just not on the table. Often, in retrospect after an incident, "everybody" thought that it was obvious, but that is another matter. Accounts of past events are uncertain as chance plays a great role (Taleb, 2007), and people have selective memory.

When each individual risk has been evaluated it is a good idea to compare them to look for any inconsistencies. A famous example from the psychologists Daniel Kahneman[8] and Amos Tversky (Kahneman, 2011) was to ask people what is most likely of:

1. A massive flood somewhere in North America next year, in which more than 1000 people drown.
2. An earthquake in California sometime next year, causing a flood in which more than 1000 people drown

Most people automatically thought risk 2 had the highest likelihood, even if it is in fact a subset of risk 1. Below is a Venn-diagram illustrating the situation. Why are people making such mistakes?

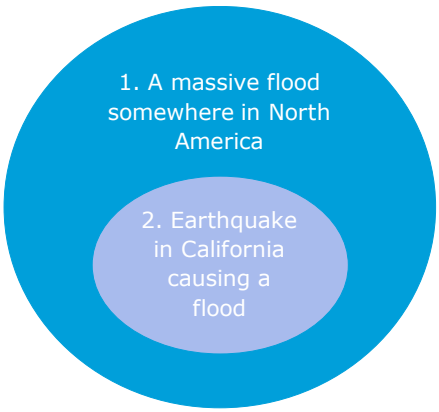


Figure 9 Venn-diagram of risk 1 and 2.

According to Kahneman and Tversky, the California earthquake scenario is more plausible, because everybody is familiar with it (availability bias). Here plausibility and likelihood are mixed up.

In cyber security, we may make the same type of mistake when comparing the two risks:

[8] Fact: Daniel Kahneman received the Nobel prize in economics in 2002, not having had a single course in economics.

A. Malware attack corrupting files in system S

B. Ransomware attack corrupting files in system S

Lately, ransomware attacks have been reported frequently in the media, but ransomware is a subset of malware. There are other types of malware that also could corrupt files.

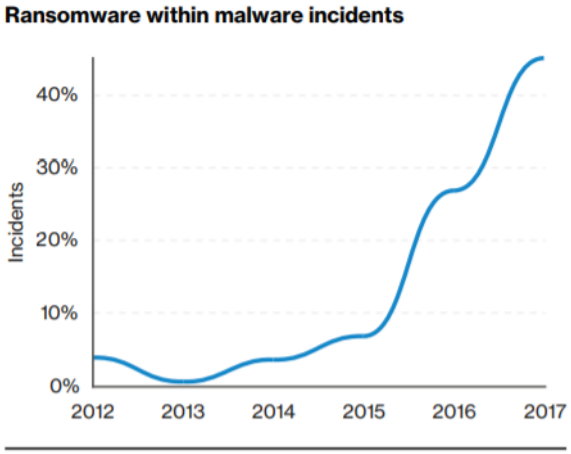


Figure 10 - Trend in ransomware attacks (Verizon 2018)

Another error is to only look at what can be seen. An example is the missing bullet holes. During World War II the secret Statistical Research Group (SRG) was given the task to analyse statistics on bullet holes in bomber planes that returned from missions in Europe, to give the US Air Force recommendations on where to armour the planes. This is an optimization problem, as too much armour all over would make the planes heavy and difficult to manoeuvre, too little armour or in the wrong places would make the planes vulnerable. They had the following statistics:

Section of plane	Bullet holes per square foot
Engine	1.11
Fuselage	1.73
Fuel system	1.55
Rest of the plane	1.8

Figure 11 – Statistics on bullet holes (from Ellenberg, 2016)

The Air Force officers thought it was a good idea to armour the planes where there were most holes per square foot. Abraham Wald in the SRG thought differently. One should armour the planes in places where there were the least number of holes, on the engines. The planes that were hit in the engines were less likely to make it back home, than planes that were hit elsewhere. Only the planes that were able to return, and not those that were shot down, were part of the statistical material. This is called “survivorship bias” (Ellenberg, 2016).

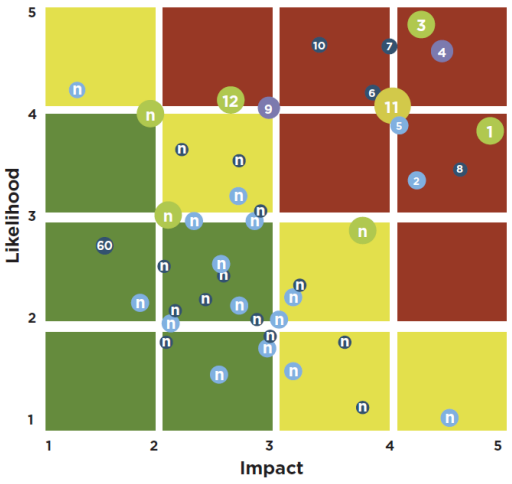
Not all cases of information security incidents are reported, and some are not discovered by those who are being attacked. Hence, it is difficult to obtain reliable statistics on what happens, how much it costs, etc. (NSR 2016, Verizon 2018).

4 DIFFERENT WAYS OF PRESENTING RISKS

So far, we have been speaking of risk matrices with probability and consequence. Recently, the risk matrix with some modifications, has been renamed a "Heat Map".

There are various ways to do this. One way is to indicate "speed of onset" of risk. This could be indicated by how large you make the circle representing the risk in the matrix. An example is provided below.

Exhibit 7: Illustrative Heat Map



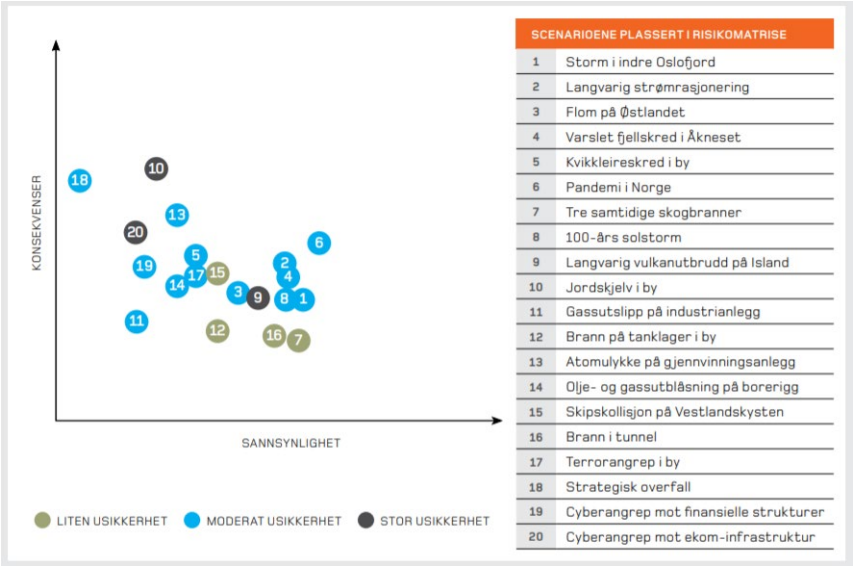
ID	Risk	I	L	V	S
1	Supply chain disruption	4.8	3.7	3.8	4
2	Customer preference shift	4.1	3.3	3.5	2
3	Copper price rise >10%	4.3	4.7	2.3	4
4	Work stoppage > 1 week	4.4	4.5	4.1	3
5	Economic downturn	4.0	3.7	3.5	2
6	Supplier consolidation	3.8	4.2	3.2	1
7	Local competitors enter	3.9	4.5	3.6	1
8	New substitutes available	4.5	3.6	4.2	1
9	Cost of capital rise >5%	2.9	4.0	2.9	3
10	Tighter emission standards	3.4	4.6	2.9	1
11	FCPA violation	4.0	4.0	3.3	5
12	Exchange rate fluctuations	2.7	4.1	2.7	4
n	. . .	...	...	...	...
60	Impairment of assets	1.6	2.7	1.6	1

Dots represent risk #1 - #n
Dot size reflects speed of onset:
Very Low Low Medium High Very High

I = Impact L = Likelihood V = Vulnerability S = Speed of onset

Figure 12 – Heat map, source, Curtis and Carey, 2012

Other ways to pimp up a risk matrix are to use different symbols for risks to indicate where probability and/or consequence are uncertain. In this way, uncertainty can be visualised. The following example is from the National Risk Picture (Nasjonalt Risikobilde) for Norway regarding accidents, natural disasters and deliberate actions.



SCENARIOENE PLASSERT I RISIKOMATRISE	
1	Storm i indre Oslofjord
2	Langvarig strømrasjonering
3	Flom på Østlandet
4	Varslet fjellskred i Åkneset
5	Kvikkleireskred i by
6	Pandemi i Norge
7	Tre samtidige skogbranner
8	100-års solstorm
9	Langvarig vulkanutbrudd på Island
10	Jordskjelv i by
11	Gassutslipp på industrianlegg
12	Brann på tanklager i by
13	Atomulykke på gjennvinningsanlegg
14	Olje- og gassutblåsning på borerigg
15	Skipskollisjon på Vestlandskysten
16	Brann i tunnel
17	Terrorangrep i by
18	Strategisk overfall
19	Cyberangrep mot finansielle strukturer
20	Cyberangrep mot ekom-infrastruktur

Figure 13 – National Risk Picture for Norway, DSB, 2014. Green colour indicates small uncertainty, blue medium uncertainty, and black high uncertainty.

The UK National Risk Register of Civil Emergencies (2017) depicts risks in two matrices, each risk given a symbol. Note that there are two different scales for probability – likelihood and relative plausibility.

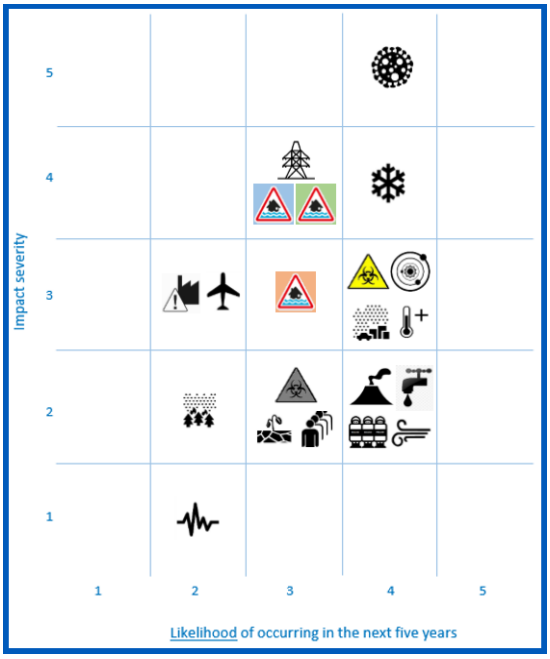


Figure 14 - Matrix A - Hazards, diseases, accidents, and societal risks (Cabinet Office, 2017)

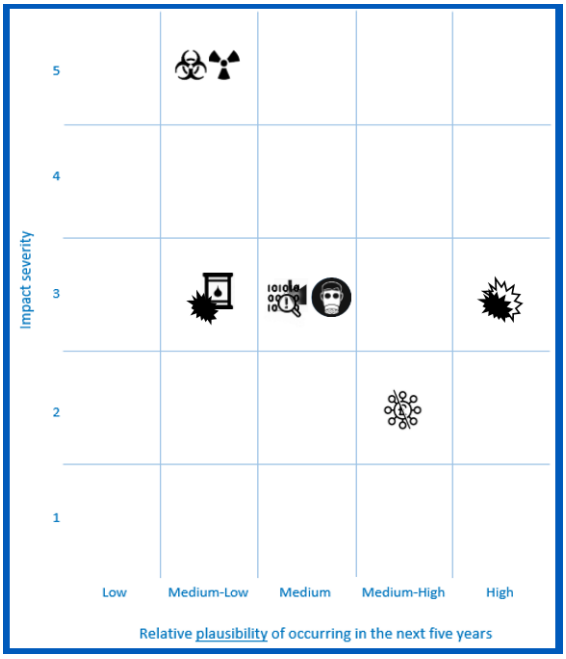


Figure 15 - Matrix B - Malicious attack risks (Cabinet Office, 2017)

Another way could be to distinguish between internal and external risks. Internal risks are those that can be handled within an organisation or a project; external risks are those that come from outside, e.g. change in politics, accidents, natural disasters and deliberate human actions.

Very high 5					
High 4	10				[5]
Medium 3				3, 7	
Low 2		6		4, [8]	
Very low 1		9			1, [2]
Prob. ↑ Cons. →	Very low 1	Low 2	Medium 3	High 4	Very high 5

Figure 16 – Heat Map where external risks are indicated in brackets [ ]

Risk matrices could also be displayed showing the current risk picture compared with the risk picture after planned actions (residual risk).

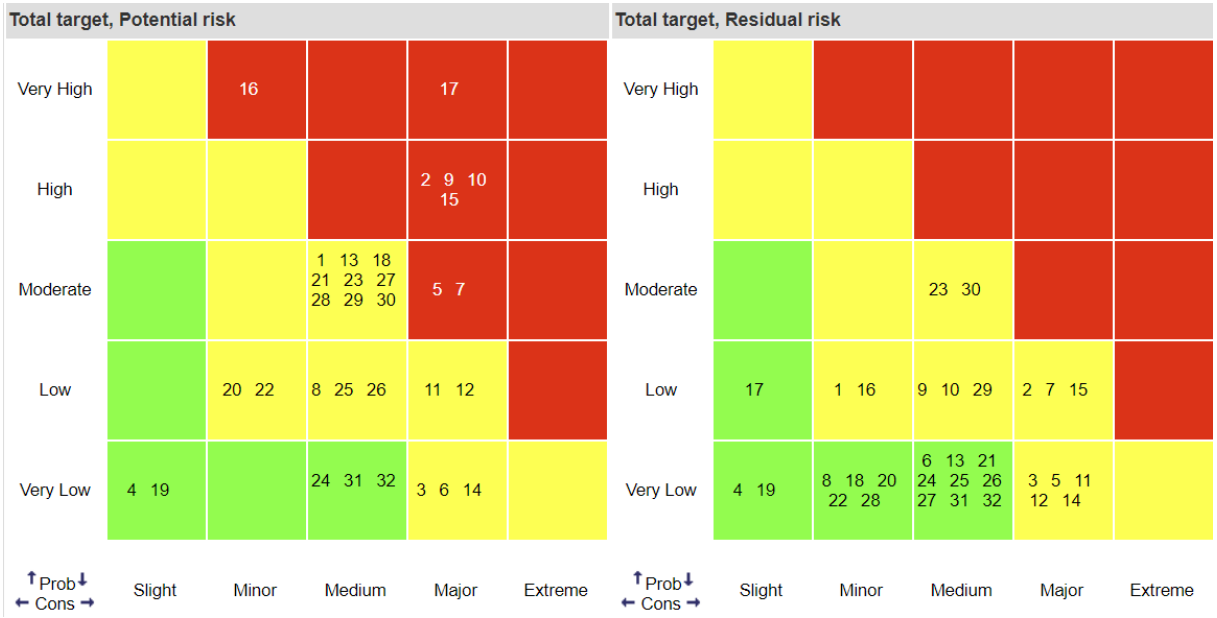


Figure 17 - Current risk picture (potential risk) compared with risk picture after actions (residual risk)[9]

Finally, risks could be presented in a list sorted according to current risk level, starting with the highest risk, followed by the second highest risk, and so on. It is also possible to add information such as risk category, i.e. indicating external or internal risk; and next review date, i.e. indicating how urgent it is to do something about the risk. Such a list of risks could also be combined with information on associated actions, responsibilities, etc., and may be more valuable than a risk matrix or a heat map alone.

9 Notice that the risk matrices in this figure are coloured differently than in the risk matrix above. This reflects various organisations' risk appetites, or risk acceptance criteria.

5 CONCLUSION

Whatever method is used for risk assessment, and how it is presented, we should not forget the main objectives:

1. To identify what could happen – the risks
2. To prioritise between important and not-so-important risks
3. To do something about the prioritised risks

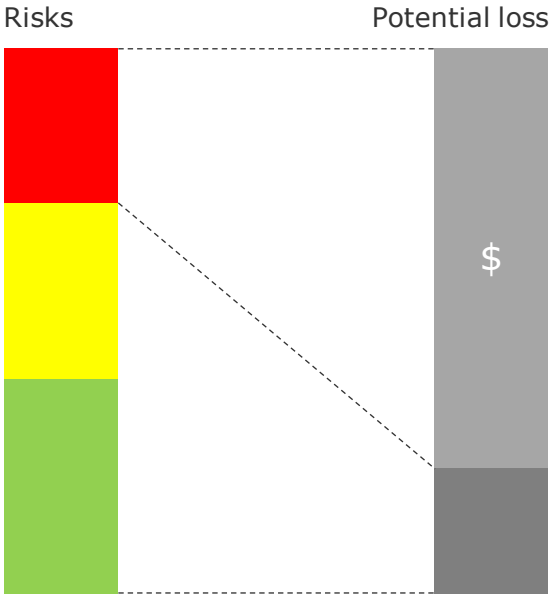


Figure 18 – By treating the most critical risks, a large amount of potential loss can be reduced

This is an application of the 20/80 rule or "the law of the vital few and the trivial many" as formulated by Juran.

In an appendix, I have provided some general examples on

A. What is certain
B. What we believe is true and has stood the test of time
C. What can probabilistically be determined
D. What can be inferred from experience (statistics)
E. What can be assumed, but is uncertain
F. More uncertainty
G. Finally, what no one has thought of

In a risk analysis, we may have to consider aspects from all domains, except for G, where we for obvious reasons may have difficulties.

Final word: A risk analysis concerning IT security probably belongs to category E.

6 REFERENCES

Lillian Ablon, Martin C. Libicki, Andrea A. Golay, Markets for Cybercrime Tools and Stolen Data, Hackers' Bazaar, RAND Corporation, 2014
https://www.rand.org/content/dam/rand/pubs/research_reports/RR600/RR610/RAND_RR610.pdf

Terje Aven, Misconceptions of risk, John Wiley, 2010

Jørgen Botnan, IKT-sårbarhetsbildet. Hvor trykker sikkerhetsskoen, NSM, 2014
https://nsm.stat.no/globalassets/dokumenter/botnan.pdf

Odd Busmundrud, Maren Maal, Jo Hagness Kiran og Monica Endregard, Tilnærminger til risikovurderinger for tilsiktede uønskede handlinger, FFI-rapport 2015/00923 https://www.ffi.no/no/Rapporter/15-00923.pdf

Cabinet Office, National Risk Register of Civil Emergencies, 2017
https://www.gov.uk/government/publications/national-risk-register-of-civil-emergencies-2017-edition

Patchin Curtis, Mark Carey, Risk assessment in practice, COSO – Deloitte & Touche LLP, October 2012
https://www2.deloitte.com/content/dam/Deloitte/global/Documents/Governance-Risk-Compliance/dttl-grc-riskassessmentinpractice.pdf

Bjørn-Ivar Davidsen, John Maynard Keynes - en sjelden fugl, Fagbokforlaget, 2018

DSB, Nasjonalt risikobilde 2014 https://www.dsb.no/globalassets/dokumenter/rapporter/nrb_2014.pdf

Jordan Ellenberg, How Not to Be Wrong – The Hidden Maths of Everyday Life, Allen Lane, 2016.
An excerpt from the chapter "Abraham Wald and the Missing Bullet Holes" is given at
https://medium.com/@penguinpress/an-excerpt-from-how-not-to-be-wrong-by-jordan-ellenberg-664e708cfc3d

Federal Emergency Management Agency (FEMA), Asset value, Threat/Hazard, Vulnerability and Risk,
https://www.fema.gov/media-library-data/20130726-1455-20490-5292/fema426ch1.pdf

University of Groningen, Decision Making in a Complex and Uncertain World. Free online course.
https://www.futurelearn.com/courses/complexity-and-uncertainty/0/steps/1824

Koen van Impe, Simplifying Risk Management, March 28, 2017
https://securityintelligence.com/simplifying-risk-management/

Daniel Kahneman, Thinking, fast and slow, Allen Lane, 2011

NSM - Nasjonal sikkerhetsmyndighet, Håndbok, Risikovurdering for sikring, Mars 2016
https://www.nsm.stat.no/globalassets/dokumenter/handboker/risikovurdering_nsm_handbok_mars2016.pdf

NSR – Næringslivets sikkerhetsråd, Mørketallsundersøkelsen, september 2016.
https://www.nsr-org.no/getfile.php/Bilder/M%C3%B8rketallsunders%C3%B8kelsen/morketallsundersokelsen_2016.pdf

Surbhi S, Difference Between Risk and Uncertainty, January 27, 2016
https://keydifferences.com/difference-between-risk-and-uncertainty.html

Nassim Nicholas Taleb, The Black Swan: The Impact of the Highly Improbable, Penguin Books, 2007

Verizon, 2018 Data Breach Investigations Report (DBIR)
https://www.verizonenterprise.com/resources/reports/rp_DBIR_2018_Report_en_xg.pdf

7 APPENDIX – FROM CERTAINTY TO TOTAL IGNORANCE

First, let us look at what is certain and not so certain, moving on to areas where we haven't the foggiest idea. The tour begins:

A. What is certain

- What can be counted, e.g. number of LEGO bricks. Two persons counting will agree on the result.
- What can be measured physically. Although there may be some measurement uncertainty, usually this can be kept under control.
- Mathematical theorems, e.g. Pythagoras equation about the relations between the squares of the sides in a right-angled triangle. It was proved over 2000 years ago, and the proof holds. In fact, there are hundreds of proofs of this theorem. To put it simply, mathematical theorems that have been proven are absolutely certain.

B. What we believe is true and has stood the test of time

- Darwinian evolutionary theory, with improvements from genetics and later findings.
- Physical theories, such as Einstein's relativity theory and quantum mechanics, have not been contradicted for the last 100 years or so. However, there are areas where Einstein's general theory of relativity and quantum mechanics cannot be reconciled, but the debate is on for which one of them is to blame, or if we need another theory encompassing both.
- Remember, Newtonian mechanics held sway for about 250 years before young Albert Einstein came along. You can still use Newtonian mechanics to calculate space travel safely to the moon, not missing the landing spot by many centimetres.

C. What can probabilistically be determined

- Cases involving a fair dice or a fair coin. Due to symmetry, by combinatorics it is possible to mathematically deduce probabilities for a lot of things. For instance, the probability of throwing two dice and getting two sixes is 1/36.
- The birthday paradox. If there are more than 23 people in a room, there is more than 50% probability that two of them have the same birthday.
- Quantum mechanics again. Despite Heisenberg's uncertainty relation between position and momentum it is possible to calculate the magnitude of that uncertainty. Also, when solving the Schrödinger wave equation, the absolute square of the wave function is the probability density for finding a particle in a special location. So, even if quantum mechanics involves uncertainty and probabilities (and Einstein didn't like it), it can be calculated.

D. What can be inferred from experience (statistics)

- The average life expectancy of people.
- The same holds for death rates due to various accidents/incidents, e.g. traffic accidents, work-related accidents, suicide, crime, etc.
- The height of people follows a normal distribution with an average value.
- The magnitude of earthquakes is distributed according to a power law. There are about ten times more quakes of magnitude 4 than magnitude 5 in an area in a given time period.
- The frequency of something failing, giving numbers like mean-time-between-failure (MTBF) and mean-time-to-restore (MTTR), that can be used to calculate availability of equipment.

E. What can be assumed, but is uncertain

- Many aspects of political theory, economic theory, sociology and psychology are uncertain. There is obviously some merit in some of it, but which part? Experts disagree. These are complicated and complex matters.
- The frequency and trends concerning various types of cyber-attacks; DDoS, viruses, ransomware, etc. This changes from year to year, and new types are frequently introduced.
- Short term forecasting of future business trends. Normally, next year's budget is based on last year's, with some tweaks and alterations due to a mixture of forecasts, goals, "visions" and hopefully, common sense.
- Global warming due to human activity. Almost everybody agrees on the large trends, but there is little agreement on the details; will the temperature rise by 2 degrees or 4 or 5 degrees within the next 50 years? How much will the sea level rise? What are the implications? And what should we do about it?

F. More uncertainty

- Long term weather forecasting is extremely difficult due to the chaotic nature of the weather. Small uncertainties are magnified non-linearly due to feedback loops. Two values with minimal differences may lead to totally different weather predictions after a period of days or weeks.
- Long term business investments. Who knows what the price of oil or some other commodity is in 20 years? And what if you must decide on a large investment today based on that uncertain knowledge?
- Long term political trends. Who saw in advance that the Soviet Union would collapse?
- Terrorism threats. There may be some indication of a threat in advance, but who, what, where and when may be extremely difficult to predict.

G. Finally, what no one has imagined

- These are the "unknown unknowns" or the "black swans". Think of 9/11, the tsunami in 2004, 22 July 2011, the financial crisis in 2008, etc.
- Typically, after some totally unexpected events, these events are later incorporated into risk assessments in the following years. Who could foresee that a volcanic eruption in Iceland would disrupt airplane flights over the northern hemisphere for many days? During the event in 2010, UK and American news reporters were every night terrified of having to pronounce "Eyjafjallajökull". Now this scenario is part of Norway's national risk picture and the UK national risk register.
- Still, there are a lot of things that could happen that nobody has thought of yet.

ABOUT DNV GL

DNV GL is a global quality assurance and risk management company. Driven by our purpose of safeguarding life, property and the environment, we enable our customers to advance the safety and sustainability of their business. Operating in more than 100 countries, our professionals are dedicated to helping customers in the maritime, oil & gas, power and renewables and other industries to make the world safer, smarter and greener.

DIGITAL SOLUTIONS

DNV GL is a world-leading provider of digital solutions for managing risk and improving safety and asset performance for ships, pipelines, processing plants, offshore structures, electric grids, smart cities and more. Our open industry platform Veracity, cyber security and software solutions support business-critical activities across many industries, including maritime, energy and healthcare.